

A definition of computer security

- **Computer security:** The protection afforded to an automated information system in order to attain the applicable objectives of preserving the integrity, availability and confidentiality of information system resources (includes hardware, software, firmware, information/data, and telecommunications)

NIST 1995

Principles

- **Confidentiality**
 - **Data confidentiality:** Assures that confidential information is not disclosed to unauthorized individuals
 - **Privacy:** Assures that individual control or influence what information may be collected and stored
- **Integrity**
 - **Data integrity:** assures that information and programs are changed only in a specified and authorized manner
 - **System integrity:** Assures that a system performs its operations in unimpaired manner
- **Availability:** assure that systems works promptly and service is not denied to authorized users

Challenges

1. Computer security is not simple
2. One must consider potential (unexpected) attacks
3. Procedures used are often counter-intuitive
4. Must decide where to deploy mechanisms
5. Involve algorithms and secret info (keys)
6. A battle of wits between attacker / admin
7. It is not perceived on benefit until fails
8. Requires constant monitoring

Adversary (threat agent)

An entity that attacks, or is a threat to, a system.

Attack

An assault on system security that derives from an intelligent threat; that is, an intelligent act that is a deliberate attempt (especially in the sense of a method or technique) to evade security services and violate the security policy of a system.

Countermeasure

An action, device, procedure, or technique that reduces a threat, a vulnerability, or an attack by eliminating or preventing it, by minimizing the harm it can cause, or by discovering and reporting it so that corrective action can be taken.

Risk

An expectation of loss expressed as the probability that a particular threat will exploit a particular vulnerability with a particular harmful result.

Security Policy

A set of rules and practices that specify or regulate how a system or organization provides security services to protect sensitive and critical system resources.

System Resource (Asset)

Data contained in an information system; or a service provided by a system; or a system capability, such as processing power or communication bandwidth; or an item of system equipment (i.e., a system component--hardware, firmware, software, or documentation); or a facility that houses system operations and equipment.

Threat

A potential for violation of security, which exists when there is a circumstance, capability, action, or event that could breach security and cause harm. That is, a threat is a possible danger that might exploit a vulnerability.

Vulnerability

A flaw or weakness in a system's design, implementation, or operation and management that could be exploited to violate the system's security policy.

Examples of threats

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service.	An unencrypted CD-ROM or DVD is stolen.	
Software	Programs are deleted, denying access to users.	An unauthorized copy of software is made.	A working program is modified, either to cause it to fail during execution or to cause it to do some unintended task.
Data	Files are deleted, denying access to users.	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data.	Existing files are modified or new files are fabricated.
Communication Lines and Networks	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable.	Messages are read. The traffic pattern of messages is observed.	Messages are modified, delayed, reordered, or duplicated. False messages are fabricated.

Modern Nature of Attack

1. *Automating Attacks:-*

- ✓ **Traditional Attack:** Produce Coins using machinery & Bring them into circulation.
- ✓ **Modern Attack:** Steal half a dollar from million accounts in a few minutes time digitally.

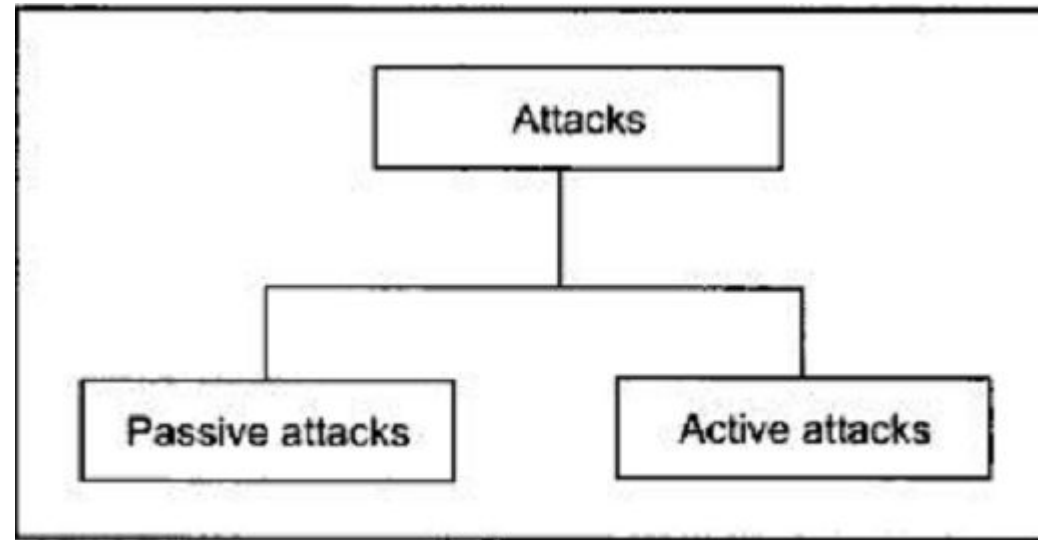
2. **Privacy Concern:-** Every Company are collecting & processing lots of information about us. Without we realizing when & how it is going to be used.

3. **Distance does not matter:-** Attack Can be launched from the distance

Types of Attack

- Attacks: **A Technical View**
 1. Theoretical Concepts behind this attack.
- ✓ **Interception:-** Copying of data & program & listening to N/W Traffic.
- ✓ **Fabrication:-**Attacker may add fake records to a database. Creation of illegal objects on the computer system.
- ✓ **Modification:-**Attacker modifies Value of DB
- ✓ **Interruption:-** Resources became unavailable, lost or unusable. Causing problems to a H/W device, erasing program, Data or OS components.

Further Grouped in to types:



└ Fig. 1.10 *Types of attacks*

Passive Attack

- Attacker *eavesdropping* or *monitoring* of data transmission.
- Tries too learn something out of it & make use of it.
- Aims to obtain information that is in transmit.
- No Modification
- Detection harder.

1. For plain text Message

- Solution prevention :- encryption

2. For Encoded Message



- Similarity -> Pattern -> Clue

Classification of Passive Attack

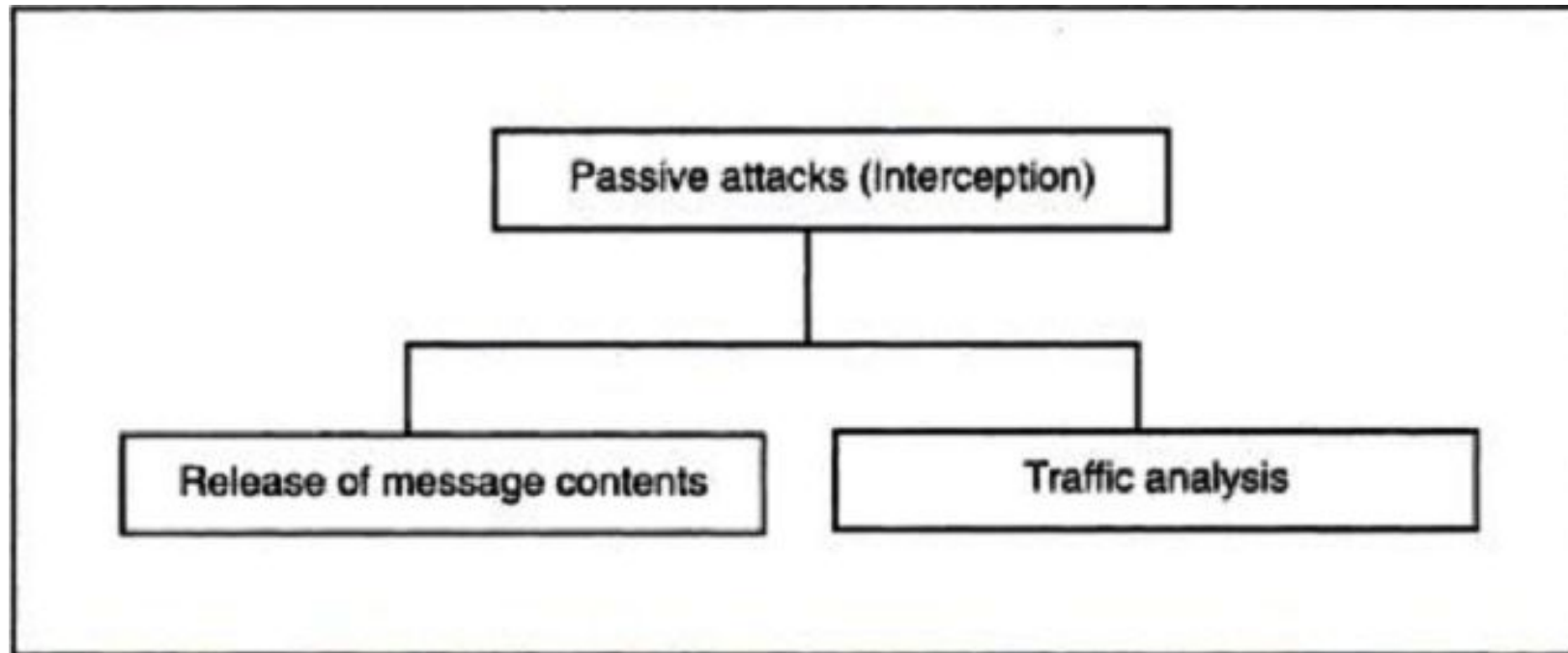


Fig. 1.7 *Passive attacks*

Active Attack

- Modification
- Creation of False Msg
- No prevention
- Solution Detection & Recovery

Classification of Active Attack

Masquerade :- *Trying to pose as another entity*

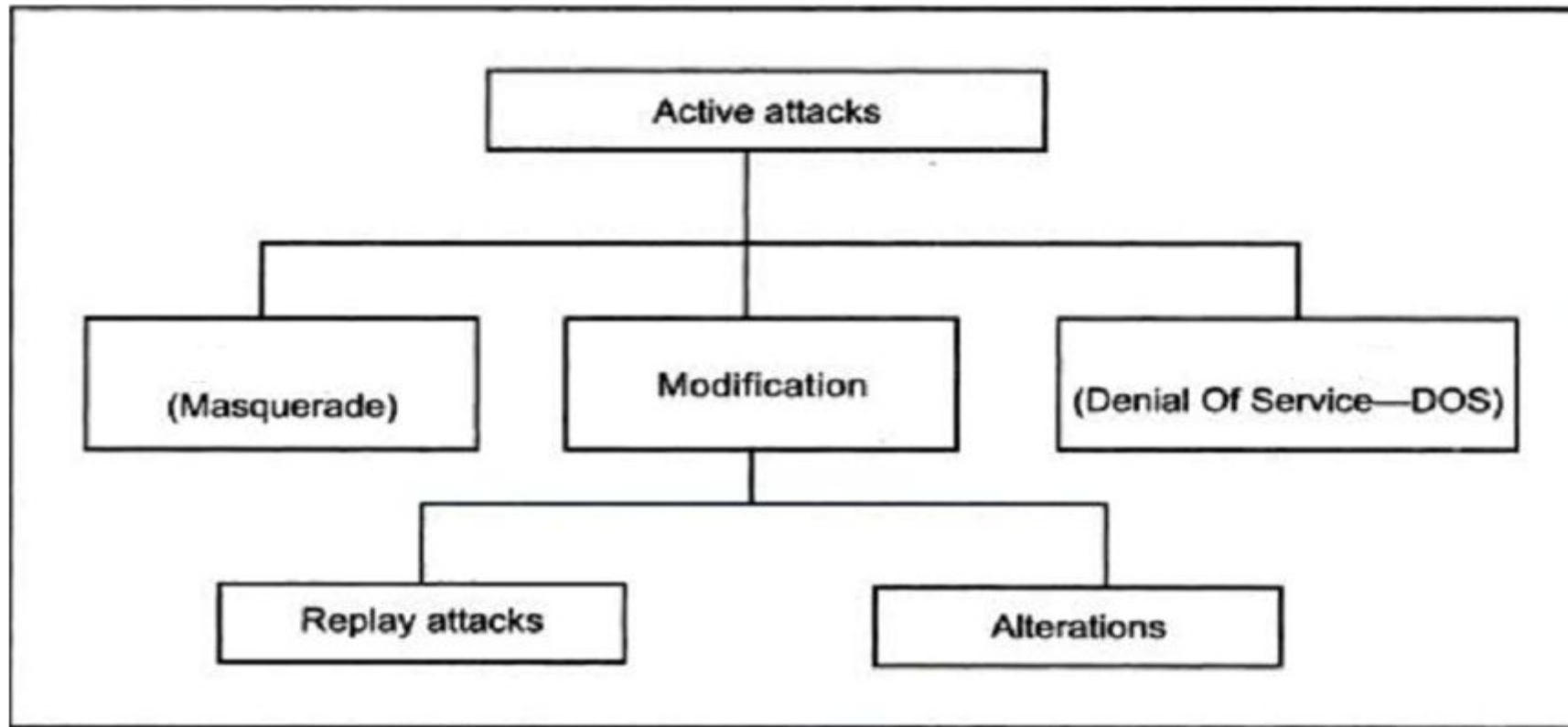


Fig. 1.8 Active attacks

2. Practical Side Of Attack

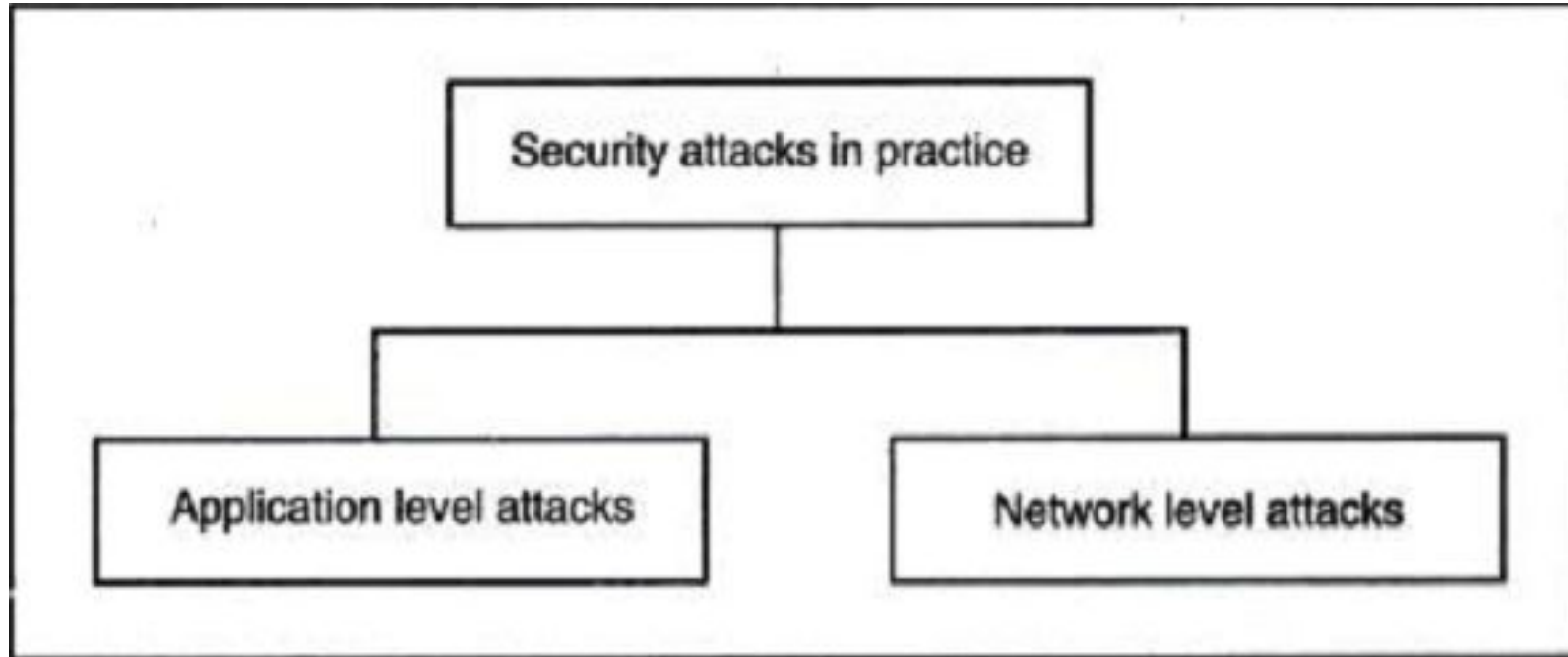


Fig. 1.9 *Practical side of attacks*

- **Application level attacks:** These attacks happen at an application level in the sense that the attacker attempts to access, modify or prevent access to information of a particular application, or the application itself. Examples of this are trying to obtain someone's credit card information on the Internet, or changing the contents of a message to change the amount in a transaction, etc.
- **Network level attacks:** These attacks generally aim at reducing the capabilities of a network by a number of possible means. These attacks generally make an attempt to either slow down, or completely bring to halt, a computer network. Note that this automatically can lead to application level attacks, because once someone is able to gain access to a network, usually she is able to access/modify at least some sensitive information, causing havoc.